CIS LINUX AUDIT · VERSIÓN 1.0.0

Manual de Operación

Operación completa de la herramienta: requisitos, privilegios, evidencias, fuentes, ejecución y resultados.

Versión 1.0.0 | Fecha 2026-11-10 | Versión operativa | Auditoría de solo lectura

Contenido

1. Propósito
2. Sistemas soportados
3. Requisitos
4. Cuenta srvinnops
5. Modelo de privilegios
6. Arquitectura de evidencias
7. Fuentes canónicas
8. Inventario
9. Preparación del host
10. Collector
11. Sudoers
12. Auditoría normal
13. Filesystem profundo
14. Generación de reportes
15. Interpretación de resultados
16. Exclusiones
17. NO APLICA
18. CONTROL EXCLUIDO y OMITIDO
19. Exclusiones de Infraestructura
20. REQUIERE REMEDIACIÓN MANUAL y REQUIERE AJUSTE MANUAL
21. Servicios systemd, kmod y usuarios interactivos
22. CIS 5.4.2.5 (PATH de root)
23. ERROR DE AUDITORÍA
24. Evidencia organizacional
25. Retiro de instrumentación
26. Troubleshooting

1. Propósito

CIS Linux Audit es una herramienta de **auditoría independiente y de solo lectura** que valida, servidor por servidor, si los controles de hardening CIS que el proveedor indicó como implementados están realmente configurados. No es una herramienta de remediación: nunca cambia la configuración del servidor auditado.

Para cada control en alcance responde: qué pide el CIS Benchmark oficial suministrado, qué indica la línea base (Excel), si el proveedor lo implementó, qué tiene realmente el servidor, con qué evidencia, si cumple CIS, qué exclusión definió Infraestructura, si la exclusión cubre el hallazgo y qué falta cuando hay desviación.

Principios que no cambian

- Recolección remota **READ-ONLY**: ningún comando modifica archivos, paquetes, servicios, usuarios, GRUB, PAM, SSH, sysctl ni firewall.
- **Fail-closed**: evidencia insuficiente nunca produce CUMPLE.
- Un problema de acceso o de evidencia es **ERROR DE AUDITORÍA**, nunca NO CUMPLE.
- El **Resultado CIS técnico** se calcula siempre separado del **Resultado final** (exclusiones y omisiones).
- CONTROL EXCLUIDO no es CUMPLE; NO APLICA siempre tiene una causa explícita.
- El objetivo operativo es el 100 % de **cobertura de validación**, no el 100 % de cumplimiento CIS.

2. Sistemas soportados

Sistema	Benchmark	Documento CIS (input/cis/)	Versión
Oracle Linux 8	ORACLE8	CIS_Oracle_Linux_8_Benchmark_v4.0.0.pdf	v4.0.0
Oracle Linux 9	ORACLE9	CIS_Oracle_Linux_9_Benchmark_v2.0.0.pdf	v2.0.0
RHEL 8	RHEL8	CIS_Red_Hat_Enterprise_Linux_8_Benchmark_v4.0.0.pdf	v4.0.0
RHEL 9	RHEL9	CIS_Red_Hat_Enterprise_Linux_9_Benchmark_v2.0.0.pdf	v2.0.0
SLES 15	SLES15	CIS_SUSE_Linux_Enterprise_15_Benchmark_v2.0.1.pdf	v2.0.1

El sistema operativo real se determina en el precheck leyendo `/etc/os-release` (ID y VERSION_ID). El grupo del inventario indica el perfil esperado; si no coincide con el detectado, el host se detiene y no se audita con un Benchmark incorrecto.

Parte 1 en RHEL 8/9

La línea base Parte 1 tiene una sola hoja (`SLES15-ORA8-9`) y aplica también a RHEL 8/9 (decisión D-P1-01, confirmada el 2026-10-23): RHEL 9 se audita con las mismas filas que Oracle Linux 9 y RHEL 8 con las de Oracle Linux 8, cada uno contra su propio Benchmark. La Parte 2 se audita completa en los cinco sistemas.

3. Requisitos

Controlador de auditoría

Componente	Requisito
Sistema	Linux con acceso SSH a los servidores (puertos y reglas de red habilitados).
Python	3.9 o superior, con los paquetes de requirements.txt: openpyxl ≥ 3.0 y PyYAML ≥ 5.4.
Ansible	ansible-core ≥ 2.13 (solo se usa el módulo ansible.builtin.raw; no se copian módulos al servidor).
PDF CIS	poppler-utils (pdftotext) solo para reconstruir el catálogo CIS con 'preparar --reconstruir-catalogo'.
Informe del proveedor (opcional)	WeasyPrint, solo para el PDF de 'informe-proveedor' (sin WeasyPrint se genera el HTML).
Llave SSH	Llave privada de la cuenta de auditoría FUERA del directorio del proyecto, con permisos 0600.

Servidor auditado

Componente	Requisito
Cuenta	srvinnops (cuenta de auditoría) con acceso SSH por llave; sin contraseña en el inventario.
Privilegios	Sin sudo general. Única autorización: el recolector principal por ruta fija, SHA-256 y sin argumentos.
Recolector principal	cis-audit-collect 1.8.0 instalado por Infraestructura en /usr/local/libexec/cis-audit/cis-audit-collect (root:root 0755).
Recolector FS	cis-audit-collect-fs 1.1.0, solo durante una ventana autorizada de filesystem profundo.
Paquetes	Ninguno adicional: se usan utilidades base del sistema (bash, coreutils, grep, awk, sed, rpm, systemctl en modo consulta).

Instalación del proyecto en el controlador

```
cd cis-linux-audit
python3 -m pip install --user -r requirements.txt
python3 src/auditar.py --version
python3 src/auditar.py preparar
python3 src/auditar.py demo
```

`demo` genera una ejecución completa con evidencia SINTÉTICA en `results/` sin conectarse a ningún servidor: confirma que la instalación funciona. Puede borrarse después.

> **Nuevo servidor Ansible**
> Traslado del paquete, ubicación de la llave de srvinnops, known_hosts y verificación: Instalación y Traslado del Controlador.

4. Cuenta srvinnops

`srvinnops` es la cuenta con la que el controlador se conecta por SSH. Es una cuenta **sin privilegios**:

- Autenticación exclusivamente por llave (BatchMode=yes, PasswordAuthentication=no). El inventario nunca contiene contraseñas.
- No tiene sudo general: el precheck muestra `sudo -n general=no` y eso es lo esperado.
- Su única autorización sudo es la regla `CIS_AUDIT_COLLECT` (recolector principal) y, solo durante una ventana de filesystem profundo, `CIS_AUDIT_COLLECT_FS`.
- No instala archivos, no modifica sudoers, no abre shells de root ni ejecuta comandos privilegiados arbitrarios.

Verificaciones de solo lectura que Infraestructura puede ejecutar como root en el servidor:

```
getent passwd srvinnops
sudo -l -U srvinnops
```

La salida de `sudo -l -U srvinnops` debe mostrar únicamente la autorización del recolector (más los privilegios que la cuenta tuviera antes del cambio, que no deben aumentar).

5. Modelo de privilegios

La recolección se divide en tres niveles. Cada uno se usa solo si es necesario:

Nivel	Qué ejecuta	Cómo
Recolector normal	Comandos de consulta sin privilegios (rpm -q, systemctl is-enabled, lectura de archivos legibles…).	Script generado por ejecución; viaja en base64 por Ansible raw y se ejecuta con bash -s (no se escribe en el servidor).
Recolector principal	Evidencia que exige root (sudoers, /etc/shadow sin hashes, sshd -T, auditd, GRUB, rsyslogd -N1, logrotate -d…).	sudo -n /usr/local/libexec/cis-audit/cis-audit-collect sin argumentos; autorizado en sudoers por SHA-256.
Recolector FS	Recorridos completos de filesystem (7.1.11, 7.1.12, 7.1.13, 6.3.3.6, 7.2.9).	sudo -n /usr/local/libexec/cis-audit/cis-audit-collect-fs sin argumentos; solo con --filesystem-profundo y ventana autorizada.

> **Gate obligatorio**
> Antes de recolectar, el precheck verifica el recolector principal (archivo regular, root:root, modo, ACL, directorios padre, directorios del PATH, SHA-256 y autorización `sudo -n -l`). Si no es **CONFIABLE**, `ejecutar` se detiene sin ejecutar ningún control CIS (ni auditoría parcial).

La regla sudoers fija la ruta, el digest SHA-256 y `""` (sin argumentos). Si el script cambia un solo byte, sudo deja de autorizarlo. La identidad de la instrumentación de auditoría es el SHA-256 de los bytes exactos de `/etc/sudoers.d/cis_audit`.

6. Arquitectura de evidencias

Cada ejecución es independiente y se guarda completa en `results/<RUN_ID>/`. Nunca se sobrescribe una ejecución anterior.

```
results/<RUN_ID>/
├── metadata.json              versión, operador, SHA-256 de fuentes, recolectores,
configuración
├── resultados.json            resultados normalizados (fuente de los reportes)
├── resumen_ejecucion.json     resumen por host
├── gate_recolectores.json     decisión del gate por host
├── evidence/<host>/
│   ├── precheck/              precheck.json, precheck_ansible.json
│   ├── raw/                   recolector.out, privilegiado.out, filesystem.out, estado.json
(crudo, redactado)
│   ├── system_info/           system.json
│   └── controls/<BENCHMARK>_<CIS>/
│       ├── cis/               metadata.json, commands.txt, stdout.txt, stderr.txt
│       ├── exclusion_F<fila>/ evidencia de la exclusión (si aplica)
│       └── result_F<fila>.json
├── logs/                      ejecucion.log, ansible_precheck.log,
ansible_recoleccion_<host>.log
├── scripts/                   recolector_<BENCHMARK>[_sinsudo].sh usados en la ejecución
└── reports/
    ├── cis_hardening_audit_<SERVIDOR>.html
    ├── cis_hardening_audit_<SERVIDOR>.xlsx
    └── resultados_reporte.json
```

- La evidencia cruda se redacta (contraseñas, hashes, llaves, tokens) antes de persistirse y no se modifica después.
- Los reportes se regeneran desde resultados.json sin volver a conectarse (comando `reportes`).
- Nombre de ejecución: `AAAAMMDDTHHMMSS_<HOST>` (p. ej. `20261015T143000_VM-ORA9-PRD-01`); precheck: `…_PRECHECK`; reevaluación: `…_REEVALUACION`.

7. Fuentes canónicas

Fuente	Ubicación	Define
Línea base Parte 1	input/baseline/Linea Base - Analisis de Impacto _Parte1.xlsx	Controles P1, observaciones, exclusiones P1 (columna 'Exclusiones de Infraestructura').
Línea base Parte 2	input/baseline/Linea Base - Analisis de Impacto _Parte2.xlsx	Controles P2, propuesta del proveedor, exclusiones P2 (columna 'EXCLUSIONES (Infraestructura Linux)').
Banner MOTD	input/baseline/files/p1/Message_Day	Texto aprobado de /etc/motd (CIS 1.7.1).
Banner de login	input/baseline/files/p1/login_banner	Texto aprobado de /etc/issue y /etc/issue.net (CIS 1.7.2 y 1.7.3).
CIS Benchmarks	input/cis/*.pdf	Requisito técnico oficial de cada control (fuente principal).
Políticas del sitio	config/listas_aprobadas.yml	Método de logging (rsyslog), reglas rsyslog, logrotate, IPv6, pwquality.
Prerrequisitos internos	config/prerrequisitos_parte1.yml	Criterios PRE-1..PRE-5 (fuera de los indicadores CIS). PRE-3 compara por fingerprint SHA256 las llaves autorizadas de iacolcoauto y ansible_test (recolector principal 1.5.0 o posterior).
Mapeo	config/mapeo_parte1.yml, config/revisiones_mapeo.yml	Trazabilidad Excel → control CIS vigente.

Los archivos de `data/` (matrices de alcance, catálogo CIS extraído y exclusiones normalizadas) se **generan** desde estas fuentes con `python3 src/auditar.py preparar` y registran el SHA-256 de cada Excel. Antes de `plan`, `precheck`, `ejecutar`, `reevaluar` y `demo` el proyecto comprueba que `data/` corresponde exactamente al Excel vigente; si no, se detiene y pide ejecutar `preparar`.

> **Si cambia un Excel**
> Ejecute `python3 src/auditar.py preparar` y verifique que termine con `Verificación de coherencia de data/: OK`. No edite manualmente los archivos de `data/`.

8. Inventario

El inventario por defecto es `inventory/hosts.yml` (no se entrega: se crea a partir de `inventory/hosts.yml.example`). El grupo indica el perfil esperado.

```
all:
  vars:
    ansible_user: srvinnops
    ansible_ssh_private_key_file: ~/.ssh/srvinnops   # fuera del proyecto, 0600
    ansible_port: 22
  children:
    rhel_oracle_8:
      hosts:
        VM-OL8-PRD-01:
          ansible_host: 10.0.0.11
    rhel_oracle_9:
      hosts:
        VM-ORA9-PRD-01:
          ansible_host: 10.0.0.21
    sles_15:
      hosts:
        VM-SLES15-PRD-01:
          ansible_host: 10.0.0.31
```

- Grupos válidos: `rhel_oracle_8`, `rhel_oracle_9`, `sles_15`.
- Obligatorios por host: `ansible_host`, `ansible_user`, `ansible_ssh_private_key_file`.
- Prohibido: `ansible_password`, `ansible_ssh_pass`, `ansible_become_pass`.
- La llave privada no puede estar dentro del proyecto y debe tener permisos 0600 o más restrictivos.
- `--limit` acepta solo nombres de host explícitos del inventario (no grupos, `all` ni comodines); máximo `ejecucion.max_hosts_por_ejecucion` (3) hosts por ejecución.

9. Preparación del host

1. Infraestructura confirma que la cuenta `srvinnops` existe y acepta la llave del controlador.
2. Infraestructura registra el estado PRE de privilegios: `sudo -l -U srvinnops`.
3. Infraestructura instala el recolector principal 1.8.0 y `/etc/sudoers.d/cis_audit` (documento Instalación de Collectors).
4. El auditor ejecuta `precheck` y confirma **CONFIABLE** y **PERMITIDO**.
5. Solo si se requiere filesystem profundo y hay ventana autorizada: instalación temporal del recolector FS.

> **La herramienta nunca instala nada en el servidor**
> Ni el recolector ni sudoers se instalan por Ansible, SSH o la cuenta srvinnops. Siempre lo hace Infraestructura (root) mediante cambio controlado.

10. Collector

El recolector principal vigente es **cis-audit-collect 1.8.0** (único recolector principal de la versión 1.0.0; reemplaza funcionalmente a las versiones anteriores y es un superconjunto seguro de ellas).

Dato	Valor
Archivo	/usr/local/libexec/cis-audit/cis-audit-collect
Versión	1.8.0
SHA-256	f4d5a4a7166e52e906329b7e374db6877e3599182ebe299c58648715d01cf257
Propietario / modo	root:root 0755
Entregables	collectors/principal-1.8.0/

Regenerar los entregables (no instala nada; verifica que coinciden con `config/audit.yml`):

```
python3 src/auditar.py generar-recolector-privilegiado
```

Garantías del script: sin argumentos, stdin cerrado, entorno reconstruido (`env -i`), PATH fijo, `umask 0077`, sin escritura de archivos ni temporales, sin `source`, sin shells de login, redacción fail-closed (autoprueba + PIPESTATUS), GRUB y /etc/shadow solo como indicadores, sin recorridos completos de filesystem. Bloques esperados por ejecución: 43 (RHEL/Oracle Linux 9), 43 (RHEL/Oracle Linux 8) y 44 (SLES 15).

11. Sudoers

Dato	Recolector principal	Recolector FS (temporal)
Archivo	/etc/sudoers.d/cis_audit	/etc/sudoers.d/cis_audit_fs
SHA-256 de los bytes exactos	3c7af32ec498d5e5606c00ad5bec01631ca938454b8a6cfe8ad2ce795ac4f7e9	f406f580f372a3b13e93e6d4f0feef3b5f
SHA-256 semántico (comprobación adicional)	0cbf303af05d3e111b65f2e99b2e781a4b7111239dff295c0e983ce988537b77	55d4c84dcbd6c104400c6238c748ee4
Propietario / modo	root:root 0440	root:root 0440
Regla	srvinnops ALL=(root) NOPASSWD: CIS_AUDIT_COLLECT	srvinnops ALL=(root) NOPASSWD: CI

Cada regla autoriza un único comando: `sha256:<digest> <ruta fija> ""`, con `env_reset`, `secure_path`, `!setenv` y `umask=0077`. Se valida siempre con `visudo -cf` antes de instalar y con `visudo -c` después.

> **Instrumentación de auditoría**
> La regla NOPASSWD de srvinnops es instrumentación temporal de la auditoría, no una excepción CIS. Solo se reconoce como tal (y no como hallazgo en CIS 5.2.4) si el archivo coincide byte a byte con el SHA-256 aprobado. Cualquier cambio, incluso un comentario, la convierte en hallazgo.

12. Auditoría normal

```
python3 src/auditar.py plan --limit VM-ORA9-PRD-01 --detalle      # dry-run local, sin conexión
python3 src/auditar.py precheck --limit VM-ORA9-PRD-01              # read-only:
conectividad, SO y recolector
python3 src/auditar.py ejecutar --limit VM-ORA9-PRD-01              # precheck + gate +
recolección + evaluación + reportes
```

Comando	Códigos de salida
preparar	0 coherente · 3 data/ incoherente con las fuentes
plan	0 validaciones OK · 2 --limit inválido · 3 alguna validación previa falló · 6 data/ desactualizado
precheck	0 gate PERMITIDO · 4 gate BLOQUEADO · 2 inventario/--limit inválido · 6 data/ desactualizado
ejecutar	0 completado · 3 validaciones previas fallidas · 5 gate BLOQUEADO (no se ejecutó ningún control) · 2 · 6
generar-recolector-*	0 OK · 3 el script no supera las verificaciones · 4 no coincide con config/audit.yml

Durante `ejecutar` el log de la consola se guarda también en `results/<RUN_ID>/logs/ejecucion.log`.

13. Filesystem profundo

Los controles que exigen recorrer filesystems completos (7.1.11 archivos world-writable, 7.1.12 archivos sin dueño, 7.1.13 SUID/SGID, 6.3.3.6 uso de comandos privilegiados y 7.2.9 dotfiles de usuarios) no se ejecutan en una auditoría normal: quedan como **REQUIERE VALIDACIÓN MANUAL** con motivo `PENDIENTE_AUDITORIA_PROFUNDA`.

Para cubrirlos se necesita una **ventana autorizada**, la instalación temporal del recolector FS y la opción explícita:

```
python3 src/auditar.py precheck --limit VM-ORA9-PRD-01 --filesystem-profundo
python3 src/auditar.py ejecutar --limit VM-ORA9-PRD-01 --filesystem-profundo
```

- El recorrido usa -xdev, excluye /proc, /sys y /run, aplica nice -n 19 / ionice -c3 y timeouts.
- Un recorrido truncado o incompleto nunca produce CUMPLE.
- `ejecucion.auditoria_filesystem_profunda` debe permanecer en `false`: el filesystem profundo solo se activa con la opción explícita y el recolector FS CONFIABLE.
- Al terminar, Infraestructura retira el recolector FS y su sudoers.

14. Generación de reportes

```
python3 src/auditar.py reportes --run-id 20261015T143000_VM-ORA9-PRD-01
python3 src/auditar.py reevaluar --run-id 20261015T143000_VM-ORA9-PRD-01 --motivo "nueva
política aprobada"
python3 src/auditar.py informe-proveedor
```

Entregable	Uso
reports/ cis_hardening_audit_<SERVIDOR>.html	Reporte visual principal (el nombre incluye el servidor auditado): resumen ejecutivo, indicadores, controles con filtros, exclusiones, pendientes, prerrequisitos, errores y, en cada control, el botón «Ver evidencia» con su ficha ordenada.
reports/ cis_hardening_audit_<SERVIDOR>.xlsx	Matriz detallada: hojas de resumen, controles P1/P2, exclusiones, pendientes, evidencias, errores, fuera de alcance, conflictos y controles CIS únicos.
reports/resultados_reporte.json	Integración y automatización (mismo contenido normalizado que resultados.json).
informe_proveedor/<FECHA>/ informe_remediacion_cis.{html,pdf}	Informe consolidado para el proveedor de remediación, con varios servidores: matriz de hallazgos por servidor y, por control, qué se espera, qué se encontró en cada servidor, qué falta y la remediación de referencia del Benchmark CIS, más las exclusiones de Infraestructura que el servidor no cumple (NO APLICADA, NO VERIFICADA o con advertencia). Cada control es plegable en el HTML. Por defecto toma la última ejecución de cada servidor (<code>--run-id</code> repetible para elegirlas).

`reportes` regenera los tres entregables de la misma ejecución. `reevaluar` evalúa de nuevo la evidencia almacenada (sin conexión) y crea una ejecución **nueva** `…_REEVALUACION`; la original no se modifica.

15. Interpretación de resultados

Cada control muestra dos resultados: el **Resultado CIS técnico** (solo el requisito del Benchmark) y el **Resultado final** (después de aplicar exclusiones de Infraestructura y omisiones por proceso independiente). El detalle completo de estados y fórmulas está en Modelo de Resultados y Cumplimiento.

Indicador	Pregunta que responde
Cumplimiento CIS técnico	De lo evaluable técnicamente, ¿cuánto cumple el CIS?
Cobertura técnica CIS	¿Qué parte de las filas YES pudo evaluarse técnicamente?
Cumplimiento final de línea base	Considerando exclusiones aprobadas, ¿cuánto cumple la línea base?
Cobertura de validación	¿Qué parte de las filas YES tiene una conclusión trazable?

Lectura recomendada: 1) cobertura de validación (¿se puede concluir?), 2) pendientes y errores (¿qué falta?), 3) NO CUMPLE con su motivo y qué falta, 4) cumplimiento final de línea base y cumplimiento CIS técnico, siempre por separado.

Ficha de evidencia de cada control

El botón **Ver evidencia** abre, a todo el ancho y debajo del control, una ficha con siempre el mismo orden (también en la columna «Evidencia organizada» del Excel):

1. **Resultado y conclusión**: resultado CIS técnico → resultado final y el motivo, con los elementos en viñetas.
2. **Qué exige el CIS**: el valor esperado de cada comprobación decisoria y la referencia al Benchmark.
3. **Dónde se buscó**: archivos, carpetas, comandos, estado del kernel, servicios o base RPM consultados.
4. **Qué se encontró**: cada comprobación con ✔ cumple, ✘ no cumple, ℹ informativo (no decide), ⚠ error o ‣ pendiente, con su valor esperado y encontrado. En journald y rsyslog se listan además los archivos de configuración realmente leídos, en orden de precedencia.
5. **Exclusión de Infraestructura**: texto de la línea base, si se aplicó y qué hallazgos cubre y cuáles no.
6. **Qué falta** (solo si no cumple), **trazabilidad** (fila Excel, control CIS, mapeo, página del Benchmark) y, plegados, los comandos ejecutados y los datos técnicos completos.

Filas fuera de alcance y estados de mapeo

Término	Significado
FUERA DE ALCANCE	Fila P2 que existe en el CIS suministrado y cuya «PROPUESTA DE NTTDATA DE IMPLEMENTACIÓN DE CONTROL» es NO: el proveedor NTTDATA propuso no implementarla. Se muestra como «Omitido por PROPUESTA DE NTTDATA DE IMPLEMENTACIÓN DE CONTROL = NO: el proveedor NTTDATA propuso no implementarlo».
RETIRADO EN CIS ACTUAL	Fila P1 o P2 cuyo control no existe en el Benchmark suministrado, independientemente de la propuesta del proveedor (no se le atribuye la propuesta NO); el motivo se indica por fila.
Parte 1 no confirmada	Fila P1 cuyo sistema no está confirmado por la línea base; no se evalúa. Desde el 2026-10-23 la hoja P1 aplica a Oracle Linux 8/9, RHEL 8/9 y SLES 15, por lo que normalmente esta lista está vacía.
MAPEADO	Correspondencia directa Excel → CIS (mismo número y requisito).
MAPEADO_TITULO_ACTUALIZADO	Mismo requisito con número y/o título distinto en el CIS vigente (renumeración).
MAPEADO_CONSOLIDADO	Varias filas del Excel → un único control CIS: se evalúa una vez y se informa en cada fila.
MAPEADO_DIVIDIDO	Una fila del Excel → varios controles CIS: cumple solo si cumplen todos.
RETIRADO	El control no existe en el CIS suministrado.

En la tabla de filas fuera de alcance el motivo empieza siempre por el estado de mapeo, en negrilla y subrayado (**Mapeo CIS: …**), seguido de su significado y de la causa de omisión.

Las listas largas de la tabla de controles (por ejemplo, los binarios SUID) muestran los primeros 8 elementos y el enlace ▸ **Ver los N restantes**, que despliega la lista completa en la misma celda.

16. Exclusiones

Las exclusiones se aplican **después** de la evaluación técnica y nunca ocultan el hallazgo CIS original.

Parte	Única fuente	Qué cubre
P1	Columna 'Exclusiones de Infraestructura' del Excel P1 + config/exclusiones_infraestructura.yml	Usuarios concretos (TIPO USUARIOS) o el control completo no aplicado en el hardening (TIPO CONTROL_NO_APLICADO). Las decisiones de Infraestructura posteriores a la línea base (2026-10-27) se registran en el YAML, solo como usuarios y con alcance por sistema operativo; se UNEN a los de la celda del Excel (nunca la reemplazan) y el Excel no se modifica.
P2	Columna 'EXCLUSIONES (Infraestructura Linux)' del Excel P2	Reglas que sustituyen un valor exigido por el CIS y que se verificaron en el host, o que autorizan elementos concretos (TIPO ARCHIVOS_LOG_AUTORIZADOS: archivos de log por patrón, verificados archivo por archivo contra su CONDICION).

- La columna 'Observacion' del Excel nunca es una exclusión; ningún otro YAML define exclusiones.
- Vigentes en el YAML: 5.2.4 cchaves, jcantor y srvinnops (todos los sistemas); 5.5.3 root (SLES 15); 5.5.6 nobody, rtkit y brltty (SLES 15); 5.5.6 pcpqa (solo Red Hat Enterprise Linux, campo benchmarks). Sección exclusiones_p2 (filas de la Parte 2 sin exclusión en el Excel P2, por control CIS): 7.2.8 pcpqa (solo Red Hat Enterprise Linux), validada usuario por usuario. El NOPASSWD de srvinnops en los sudoers exactos del recolector sigue clasificándose como instrumentación.
- Una exclusión cubre solo los elementos que define: cualquier otro hallazgo deja el resultado final en NO CUMPLE.
- En el reporte se muestra: elementos autorizados, hallazgos encontrados, cubiertos y no cubiertos, fuente y origen.

> **Formato de la celda P1**
> TIPO, USUARIOS o VALOR, MOTIVO y TRATAMIENTO (una clave por línea). Una celda con texto libre detiene `preparar` (fail-closed).

> **Formato P2 ARCHIVOS_LOG_AUTORIZADOS**
> TIPO: ARCHIVOS_LOG_AUTORIZADOS · ARCHIVOS: rutas bajo /var/log separadas por coma (`<usuario>` = un nombre, `[.N]` = sufijo de rotación) · CONDICION: «propietario X y modo NNNN o más restrictivo». Sin ARCHIVOS o CONDICION interpretables, la exclusión no cubre nada. Vigente: logs por usuario de VMware Tools en CIS 6.2.4.1 (propietario root, modo 0600).

17. NO APLICA

- Solo con una causa técnica documentada y permitida por el CIS (p. ej. GDM no instalado).
- **Método de logging**: rsyslog es el método corporativo principal (`config/listas_aprobadas.yml → metodo_logging`). Los controles cuya nota de aplicabilidad del Benchmark dice *"Do not apply this recommendation if rsyslog is used"* quedan NO APLICA con tipo `NO_APLICA_METODO_LOGGING` . Se aplica por Benchmark y recomendación: OL9/RHEL9/SLES15 → 7 recomendaciones del camino journald; RHEL8 v4.0.0 → solo 'ForwardToSyslog is disabled' y 'systemd-journal-remote service is not in use'; OL8 v4.0.0 → esas dos y además 6.2.1.2.1-6.2.1.2.3 (systemd-journal-remote/upload: sección 6.2 'only one is implemented' y Audit de 6.2.1.2.1 '- IF - journald will be used'; decisión del 2026-10-27, solo Oracle Linux 8). La evidencia técnica de esos controles se conserva como informativa.
- Los controles del camino rsyslog (incluido 'journald is configured to send logs to rsyslog', que exige ForwardToSyslog=yes) aplican siempre.

18. CONTROL EXCLUIDO y OMITIDO

Estados del resultado final para controles fuera de la evaluación de hardening:

- **CONTROL EXCLUIDO**: controles gestionados por un **proceso formal independiente**: actualizaciones y parches, repositorios del gestor de paquetes y llaves GPG (tipo `CONTROL_EXCLUIDO_PROCESO_INDEPENDIENTE`).
- **OMITIDO**: solo las filas de la Parte 1 con TIPO CONTROL_NO_APLICADO (3.4.3 rds y 3.4.4 tipc), tipo `CONTROL_OMITIDO_INFRAESTRUCTURA` . En la sección de exclusiones se muestran como OMITIDO, sin APLICADA ni NO APLICADA.
- El Resultado CIS técnico, la identificación CIS y la justificación se conservan.
- Nunca se convierte en CUMPLE: queda fuera del denominador del cumplimiento final y cuenta como conclusión para la cobertura de validación.

19. Exclusiones de Infraestructura

Una exclusión **Definida** solo indica que existe en la línea base. La auditoría comprueba, con la evidencia del servidor, si está realmente implementada:

Validación	Significado
APLICADA	Definida y confirmada técnicamente (verde).
NO APLICADA	Definida, pero la configuración real no corresponde a lo que declara (rojo).
NO VERIFICADA	Sin evidencia suficiente para confirmarla.

- Exclusiones de usuarios: cada usuario se valida por separado contra la configuración real (/etc/shadow, sudoers cargados por sudo, miembros del grupo de su). Si la política CIS se aplicó a un usuario

declarado como exceptuado, la exclusión es NO APLICADA para él; los usuarios que no existen en el servidor se informan aparte.
- Exclusiones de control completo: APLICADA si el servidor conserva la configuración que el CIS no permite.
- Exclusiones P2: resultado de la prueba técnica de cada regla de la exclusión. Un valor solo recomendado que no se cumple se marca en naranja como ⚠ **CON ADVERTENCIA** y no impide que la exclusión quede APLICADA: la partición /var/log/audit por debajo de 15 GB es una advertencia si la partición propia y la rotación están aplicadas.
- Exclusión de 5.2.4 (NOPASSWD), desde el 2026-10-27: tux, proactiva, iacolcoauto, ansible_test, cchaves y jcantor. srvinnops no es una excepción: su NOPASSWD se acepta solo como instrumentación de la auditoría (/etc/sudoers.d/cis_audit y cis_audit_fs, SHA-256 verificado).
- La tabla de exclusiones muestra la descripción del control, la exclusión esperada, la configuración real, la validación, la evidencia y la observación; el resultado CIS técnico y el final están en la tabla de controles.
- Los reportes no muestran referencias a los documentos de la línea base (archivo, hoja, fila ni códigos TIPO, ORIGEN o TRATAMIENTO); la trazabilidad completa queda en resultados.json.
- En la tabla de controles, «Definida» es un enlace interno (también en el PDF impreso) al detalle de la exclusión.
- La validación no cambia el resultado CIS técnico ni el final.

20. REQUIERE REMEDIACIÓN MANUAL y REQUIERE AJUSTE MANUAL

Estados finales operativos: el resultado técnico NO CUMPLE se conserva, cuentan como no cumplidos en el cumplimiento final y el reporte muestra la acción requerida. La auditoría no corrige nada.

- **REQUIERE REMEDIACIÓN MANUAL** — CIS 1.3.1.6 (*Ensure no unconfined services exist*): los procesos bajo `unconfined_service_t` (p. ej. agentes de seguridad como Trend Micro) se siguen detectando; la remediación requiere análisis especializado de políticas SELinux y coordinación con el proveedor responsable.
- **REQUIERE AJUSTE MANUAL** — CIS 7.2.9: solo cuando el único hallazgo son archivos ocultos con un modo más permisivo que el exigido (propietario y grupo correctos). Por archivo se indica usuario, modo actual y esperado, y que debe validarse con el responsable si requiere permisos de ejecución. .netrc, .forward, .rhost(s), propietario o grupo incorrectos siguen siendo NO CUMPLE.

21. Servicios systemd, kmod y usuarios interactivos

- Todas las consultas de servicios usan un único mecanismo (`systemctl is-enabled` / `is-active`). Una respuesta sin acceso a systemd (p. ej. *Failed to connect to bus: Operation not permitted* en SLES 15) nunca se interpreta como servicio detenido ni activo: el control queda sin conclusión (SYSTEMD_NO_CONSULTABLE). El recolector principal 1.8.0 repite las consultas como root; esa evidencia sustituye a la de la cuenta sin privilegios.
- cron: se usa la unidad que existe en el host (`cron.service` en SLES, `crond.service` en RHEL/ Oracle Linux).

- Demonio de tiempo único: se informa el estado de chronyd y systemd-timesyncd; dos demonios en uso, o uno habilitado pero detenido, es NO CUMPLE.
- CIS 6.3.3.19: cada herramienta (lsmod, rmmod, insmod, modinfo, modprobe, depmod) se busca en /sbin, /usr/sbin, /bin y /usr/bin y su destino se resuelve con `readlink -f`; debe coincidir con el kmod que vigila la regla de auditd (`-F path=/usr/bin/kmod`).
- CIS 7.2.8/7.2.9 — criterio de usuario interactivo: el procedimiento literal del CIS toma toda shell de /etc/shells salvo nologin. /bin/false y /bin/true no abren una sesión interactiva aunque figuren en /etc/shells (SLES 15), por lo que esas cuentas de servicio (p. ej. rtkit con home /proc) no se evalúan y se listan como excluidas con su motivo. El criterio no depende del UID.
- Una comprobación que decide en otra fila del Excel se muestra con su resultado real como informativa.
- Orden de los controles en HTML, Excel y JSON: numérico jerárquico por componente (4.2.9, 4.2.10, 4.2.11 …; 6.3.3.2 antes de 6.3.3.19). Los saltos de numeración corresponden a controles fuera de alcance; no se crean controles.

22. CIS 5.4.2.5 (PATH de root)

Análisis estático de solo lectura: nunca se ejecuta `sudo -iu`, `su -` ni `source` de los archivos de inicio. La evidencia se presenta en tres grupos: **hallazgos confirmados** (entradas cuya incorporación al PATH está demostrada; deciden NO CUMPLE), **referencias potenciales** (directorios declarados en los archivos de inicio cuya incorporación no puede demostrarse; informativas) y **limitaciones**. El recolector actual no recoge las líneas return/exit/exec de los archivos de inicio, por lo que hoy la incorporación no se puede demostrar y el resultado es REQUIERE VALIDACIÓN MANUAL, con el procedimiento manual indicado.

23. ERROR DE AUDITORÍA

Problema del proceso de auditoría (conexión, permisos, recolector no confiable, timeout, salida no interpretable). **Nunca** es incumplimiento y no entra en los denominadores de cumplimiento.

Motivo	Causa típica	Acción
PERMISOS_INSUFICIENTES	Recolector principal no instalado/ no autorizado o lectura incompleta	Instalar o corregir el recolector y sudoers; repetir.
RECOLECTOR_PRIVILEGIADO_NO_CONFIABLE	Owner, modo, ACL, directorios o SHA-256 no coinciden	Reinstalar con el procedimiento oficial.
RECOLECCION_PRIVILEGIADA_FALLIDA	@@CIS_FATAL (p. ej. filtro de redacción)	Revisar logs del host y repetir; la salida se descartó.
TIMEOUT / RC_INESPERADO / COMANDO_INEXISTENTE	Comando lento, falla o no existe	Revisar stderr en evidence/…/cis/.
HOST_SIN_EVIDENCIA	Host inalcanzable o detenido en el precheck	Revisar conectividad y el precheck.

24. Evidencia organizacional

REQUIERE EVIDENCIA ORGANIZACIONAL indica que la evidencia técnica se recolectó, pero la conclusión depende de una aprobación externa al servidor. Ejemplo vigente: CIS 7.1.13 (SUID/SGID) necesita la lista aprobada de binarios en `config/listas_aprobadas.yml → suid_sgid`.

- Pertenecer a un paquete RPM **no** significa estar autorizado; el reporte muestra ruta, modo, dueño, grupo, paquete e integridad (rpm -V).
- No se crea una lista a partir de lo encontrado en un servidor: la lista debe estar aprobada formalmente.
- Al completar la lista, se ejecuta una nueva auditoría (o `reevaluar`) para concluir.

25. Retiro de instrumentación

Al cerrar la ventana de auditoría, Infraestructura retira la instrumentación (procedimiento completo en Instalación de Collectors):

```
rm -f /etc/sudoers.d/cis_audit_fs /usr/local/libexec/cis-audit/cis-audit-collect-fs      #
recolector FS (siempre al terminar la ventana)
rm -f /etc/sudoers.d/cis_audit /usr/local/libexec/cis-audit/cis-audit-collect            #
recolector principal (al cerrar el ciclo de auditoría)
visudo -c
sudo -l -U srvinnops                        # debe coincidir con el estado PRE
```

El proyecto no ejecuta este retiro: lo realiza root en el servidor y se verifica comparando `sudo -l -U srvinnops` con el estado PRE.

26. Troubleshooting

Síntoma	Causa probable	Acción
ABORTADO: los datos de data/ no corresponden a las fuentes canónicas	Cambió un Excel o falta data/	python3 src/auditar.py preparar
ABORTADO: --limit es obligatorio	Falta --limit o se usó un grupo/patrón	Indicar nombres de host del inventario separados por coma.
inventario incompleto o inseguro	Falta ansible_user/llave, llave dentro del proyecto o permisos > 0600	Corregir inventory/hosts.yml y la llave.
SSH=FALLIDO en el precheck	Red, llave o host key	ssh -i <llave> srvinnops@<host> manual; revisar known_hosts (host_key_checking=True).
SO_NO_CORRESPONDE	El grupo del inventario no coincide con /etc/os-release	Mover el host al grupo correcto.
recolector principal: NO_INSTALADO	No existe la ruta del recolector	Instalación por Infraestructura.
recolector principal: NO_CONFIABLE	SHA, owner, modo, ACL o directorios no coinciden	Reinstalar con el procedimiento; no editar el script.
recolector principal: NO_AUTORIZADO	sudo -n -l no autoriza la ruta	Revisar /etc/sudoers.d/cis_audit (SHA y visudo -c).
gate de ejecución: BLOQUEADO	Recolector no CONFIABLE o SHA de sudoers no configurado	Corregir y repetir precheck; no se ejecutó ningún control.
Muchos ERROR DE AUDITORÍA (PERMISOS_INSUFICIENTES)	Se ejecutó sin recolector principal	Instalar el recolector y repetir la auditoría.
Controles 7.1.x en REQUIERE VALIDACIÓN MANUAL	No se ejecutó filesystem profundo	Ventana autorizada + --filesystem-profundo.
Resultado distinto al esperado en un control	Configuración real del host	Revisar el detalle del control: componentes, esperado/encontrado y evidencia.